During a quarterly architecture review, the authorization team discussed its latest projects. The security team had been loosely involved in this work for months, consulting on sensitive actions, helping classify resources, and offering guidance on how product teams should approach risk. They understood why PBAC made things easier for developers: It eliminated *ad hoc* authorization code, reduced inconsistencies, and provided the product organization with a clear way to express policies. However, the security engineers had been treating it as an application concern rather than as a way to implement organizational security.

As the authorization team explained how the policy engine evaluated every request—using a combination of identity attributes and contextual signals—something shifted for Sam. The team wasn't just modernizing how applications handled permissions; they were creating the exact kind of decision framework the security group had been struggling to envision. The realization was subtle but significant: The mechanism capable of enforcing Zero Trust across ACME wasn't a new security product. It was an architectural change already taking place inside the company as part of the engineering team's modernization efforts.

The next day, Sam gathered the security leads and laid it out plainly: "We've been thinking about Zero Trust as a network problem. It's not. It's an authorization problem. And ACME already has the beginnings of an authorization system that can support it."

That realization changed everything. If Zero Trust meant *authorizing every access*, then the main component wasn't a firewall rule or a network boundary; it was a policy engine. PBAC wasn't just helping product teams write cleaner code; it was providing ACME with a consistent, scalable way to enforce security policies everywhere: across applications, APIs, internal tools, and administrative systems. The security team started to see PBAC not just as a convenience but also as the control plane they had been overlooking.

This chapter explores how that recognition transformed ACME's security strategy. We'll examine why Zero Trust relies on continuous, contextual authorization, how PBAC provides the technical basis for implementing it, and what is needed to operationalize these ideas across an enterprise.